BTEUP EXAM NOTES | HINGLISH EDITION

Information Security

Unit 3: Cryptography, PKI and Secure Software Development

In notes ke baare me

Part A me har topic simple Hinglish me real-life example ke saath samjhaya hai, taaki beginner bhi zero se samajh sake.

Part B me important exam questions ke poore 5-marks wale answers Hinglish me diye hain.

Last me: quick revision sheet, common mistakes aur self-test.

Exam me answer English me likhna hai to English Edition PDF use karo.

Syllabus covered (Unit 3)

Basics of Cryptography, PKI, Security considerations while developing softwares.

Unit Overview aur Contents

Simple idea: Cryptography **secret writing** ka science hai: readable data ko unreadable bana dena, taaki sirf sahi insaan hi use padh sake. PKI wo system hai jo prove karta hai ki **kaunsi public key kiski hai**. Aur secure software development ka matlab hai aise programs likhna jinhe attackers tod na saken. Ye teeno milkar data ko storage, transit aur applications me protect karte hain.

Topic	Exam importance	Notes me kahan
Cryptography basics, classical ciphers	High	Part A: Topic 1 | Part B: Q1, Q9
Symmetric aur Asymmetric cryptography	Very High	Part A: Topic 2 | Part B: Q2, Q3, Q4
Hash function, Digital signature	Very High	Part A: Topic 2 | Part B: Q5, Q6
PKI, Digital certificate	Very High	Part A: Topic 3 | Part B: Q7, Q8
Software development me security	Very High	Part A: Topic 4 | Part B: Q10, Q11, Q12

Contents

Part A: Easy Explanation	Part B: Important Questions aur Answers
Topic 1: Basics of Cryptography Topic 2: Types of Cryptography, Hash, Digital Signature Topic 3: PKI Topic 4: Secure Software Development	Q1 Cryptography, terms and types (Very Likely) Q2 Symmetric key cryptography (Very Likely) Q3 Asymmetric key cryptography (Very Likely) Q4 Symmetric vs Asymmetric (Very Likely) Q5 Hash function (Likely) Q6 Digital signature (Likely) Q7 PKI and its components (Very Likely) Q8 Digital certificate (Likely) Q9 Caesar cipher, substitution and transposition (Possible) Q10 Security considerations in software development (Very Likely) Q11 SQL injection, XSS, buffer overflow (Likely) Q12 Secure SDLC (Possible)

Is unit ko kaise padhein (time: 1 din)

1) Part A ek baar padh kar samjho. 2) Part B ke answers diagram ke saath copy me likh kar practice karo. 3) Quick Revision Sheet se revise karo. 4) Self-Test bina dekhe karo.

PART A: Easy Explanation (Hinglish)

Topic 1: Basics of Cryptography

Real-life example

Tum apne dost ko ek secret code me letter likhte ho jo sirf tumhara dost jaanta hai. Koi letter chura le tab bhi samajh nahi paayega. Yahi cryptography hai.

Definition

Cryptography information ko unreadable form me badal kar (encryption) protect karne ka science hai, taaki sirf authorized log use wapas readable bana saken (decryption).

Basic terms

Term	Matlab
Plaintext	Original readable message
Ciphertext	Unreadable (encrypted) message
Encryption	Plaintext se ciphertext banana
Decryption	Ciphertext se wapas plaintext banana
Key	Secret value jo algorithm use karta hai
Algorithm (Cipher)	Encrypt/decrypt karne ka method (steps)
Cryptanalysis	Key jaane bina cipher todna

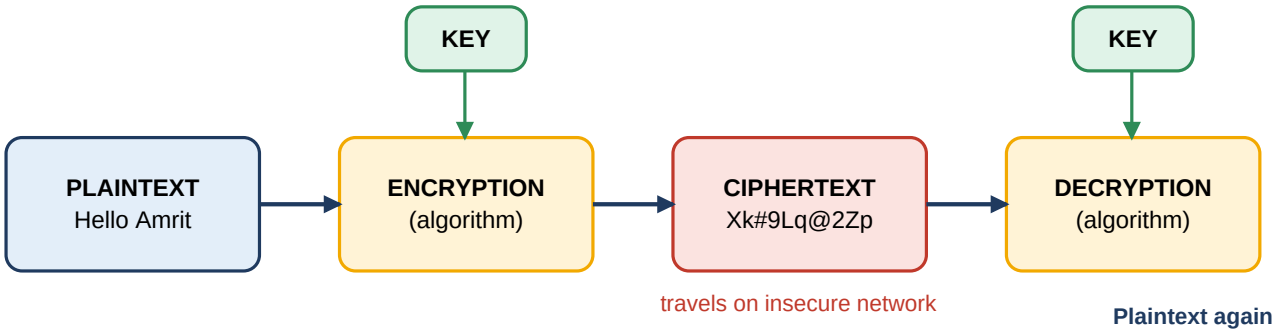


Figure 1: Encryption and decryption process

Cryptography ke goals

- **Confidentiality:** sirf sahi insaan padh sake.
- **Integrity:** message badla na ho.
- **Authentication:** sender asli ho.
- **Non-repudiation:** sender baad me mukar na sake.

Cryptography ke types

- **Classical:** purane methods, **substitution** (letters badalna, jaise Caesar cipher) aur **transposition** (letters ki jagah badalna).
- **Modern: Symmetric key**, **Asymmetric key** aur **Hash functions**.

Caesar cipher (shift = 3): each letter moves 3 places forward

Plain

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C

Cipher

HELLO -> KHOOR (H->K, E->H, L->O, L->O, O->R)

Figure 2: Caesar cipher (substitution cipher)

- **Substitution cipher:** har letter ko doosre letter ya symbol se badalna (Caesar, Monoalphabetic).
- **Transposition cipher:** letters wahi rehte hain par unki **position** badal jaati hai. Example: message ko column by column padhna.
- Classical ciphers aaj weak hain kyunki frequency analysis ya brute force se tut jaate hain.

Topic 2: Symmetric, Asymmetric, Hash and Digital Signature

2(a) Symmetric Key Cryptography

Real-life example

Ghar ki chabi: wahi chabi lock bhi karti hai aur unlock bhi. Jiske paas copy hai wo khol sakta hai. Badi problem hai chabi ko dost tak safely pahunchana.

Definition

Symmetric key cryptography me encryption aur decryption dono ke liye **wahi ek secret key** use hoti hai.

- **Bahut fast** hai aur bade data (files, disks, video) ke liye achha hai.
- **Problem:** key distribution. Secret key safely kaise share karein? Saath hi n users ko bahut saari keys chahiye.
- **DES:** 64-bit block, 56-bit key, 16 rounds. Ab weak hai. **3DES:** DES 3 baar apply.
- **AES:** 128-bit block, key 128/192/256 bits (10/12/14 rounds). Current standard.
- Anya: Blowfish, RC4 (stream cipher). Block cipher blocks par, stream cipher bit by bit kaam karta hai.

2(b) Asymmetric Key Cryptography (Public Key)

Real-life example

Slot wala letterbox: koi bhi letter daal sakta hai (public key), par box kholne ki chabi (private key) sirf malik ke paas hai.

Definition

Asymmetric key cryptography me ek **key pair** use hota hai: **public key** (sabke saath share) aur **private key** (secret rakhi jaati hai). Ek key se lock hua data sirf doosri key se khulta hai.

- **Encryption:** sender receiver ki **public** key use karta hai; receiver apni **private** key se decrypt karta hai.
- **Digital signature:** sender apni **private** key se sign karta hai; doosre uski **public** key se verify karte hain.
- **RSA:** bade prime numbers ko factor karne ki mushkil par based hai; key size 2048 bits ya zyada.
- **ECC:** bahut chhoti keys me wahi security deta hai. **Diffie-Hellman:** shared key safely exchange karne ke liye use hota hai.
- Symmetric se **slow** hai, isliye chhote data jaise keys aur signatures ke liye use hota hai.

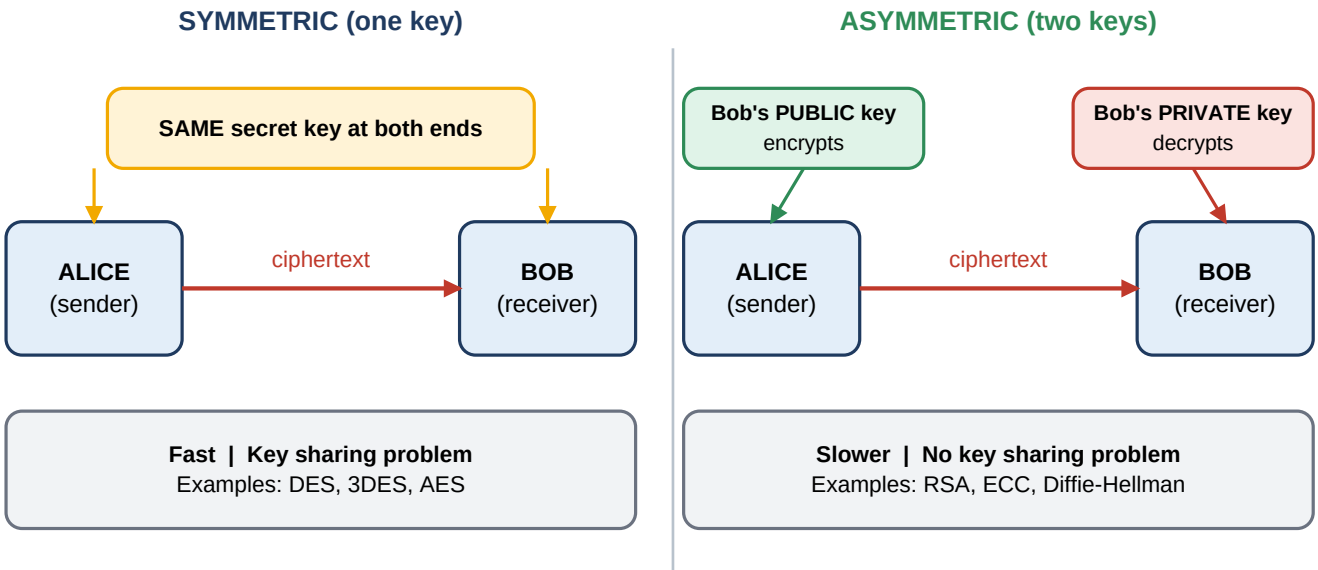


Figure 3: Symmetric vs Asymmetric cryptography

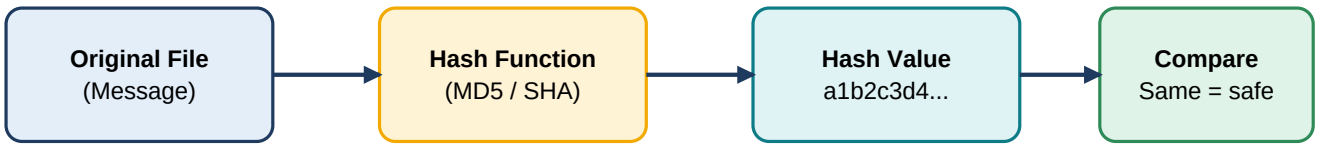
Hybrid approach (HTTPS me use hota hai)
Real systems dono use karte hain: asymmetric cryptography se **session key** safely exchange karte hain, phir fast symmetric key (AES) se asli data encrypt karte hain.

2(c) Hash Function

Real-life example
Fingerprint: insaan se fingerprint mil jaata hai, par fingerprint se insaan wapas nahi ban sakta. Insaan me chhota sa badlaav bhi fingerprint badal deta hai.

Definition
Hash function kisi bhi size ke data ko **fixed-size value** (hash / message digest) me badalta hai. Ye **one-way** function hai aur isme **koi key nahi** hoti.

- **Properties:** fixed output size, one-way (ulta nahi ho sakta), collision resistant (do inputs ka same hash nahi hona chahiye), avalanche effect (1 bit badalne se hash poora badal jaata hai), same input ka output hamesha same.
- **Examples:** MD5 (128-bit, broken), SHA-1 (160-bit, broken), SHA-256 (256-bit, secure).
- **Uses:** integrity check, password storage, digital signatures.



If even 1 character changes, the hash value changes completely (Integrity check)

Figure 4: Hash function used for integrity checking

2(d) Digital Signature

Real-life example
Ye cheque par tumhare haath ke signature aur seal jaisa hai: prove karta hai ki tumne sign kiya aur baad me kisi ne amount nahi badla.

Definition
Digital signature message ke hash ko **sender ki private key** se encrypt karne se banta hai. Ye **authentication, integrity aur non-repudiation** deta hai.

- **Signing:** message ka hash banao, phir hash ko private key se encrypt karo.
- **Verifying:** receiver signature ko sender ki public key se decrypt karta hai (Digest 1), mile hue message ka hash banata hai (Digest 2) aur compare karta hai.
- Dono match ho jaayein to message asli aur unchanged hai.

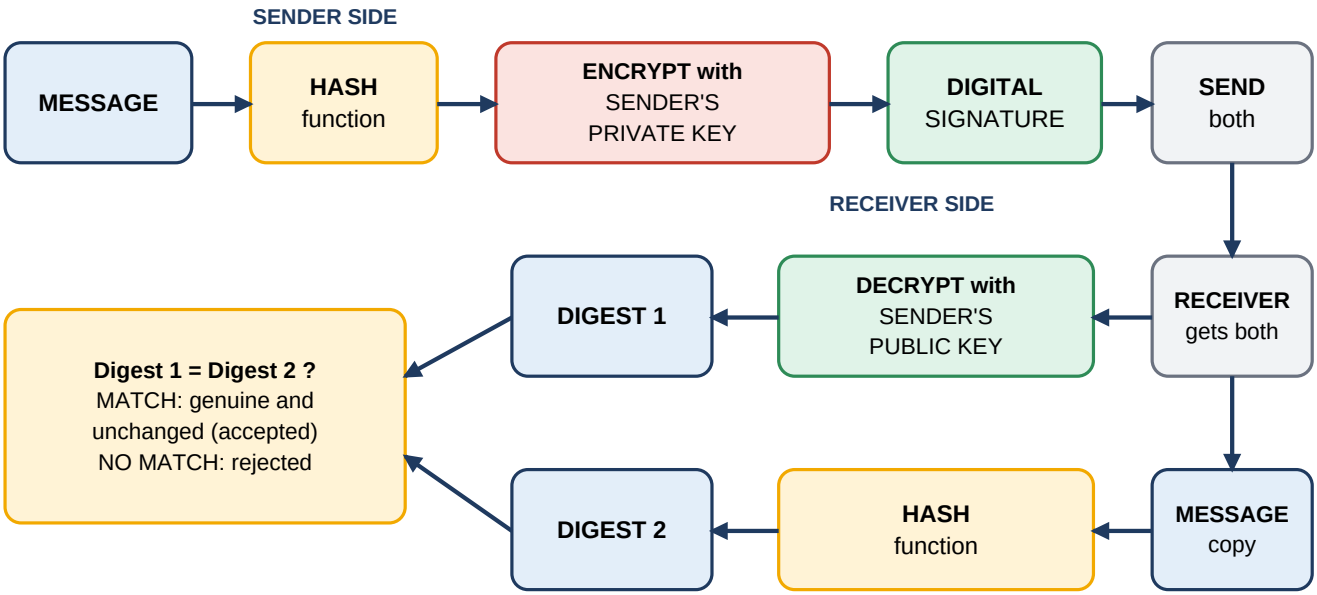


Figure 5: Digital signature: signing and verification

Topic 3: PKI (Public Key Infrastructure)

Real-life example

PKI passport office jaisa hai. Passport prove karta hai ki tum kaun ho kyunki ek trusted government office ne tumhari pehchan check karke sign kiya. Isi tarah trusted CA kisi person ya website ko check karke digital certificate sign karta hai.

Definition

PKI un logon, policies, hardware, software aur procedures ka set hai jo **digital certificates** aur public keys ko create, manage, distribute, use, store aur revoke karne ke liye chahiye.

PKI kyun zaroori hai?

Public key cryptography me kaise pata chale ki public key sach me Bob ki hai, attacker ki nahi? PKI isko certificate se solve karta hai, jo public key ko ek identity se bind karta hai aur trusted authority se signed hota hai.

PKI ke components

Component	Kaam
Certificate Authority (CA)	Trusted body jo digital certificates issue aur sign karti hai
Registration Authority (RA)	CA ki taraf se applicant ki identity verify karti hai
Digital Certificate	Electronic document jo public key ko uske owner se jodta hai (X.509)
Public / Private key pair	User ki keys jo encryption aur signing ke liye use hoti hain
Directory / Repository	Certificates aur revocation lists store karti hai
CRL and OCSP	Batate hain ki certificate revoke hua hai ya nahi

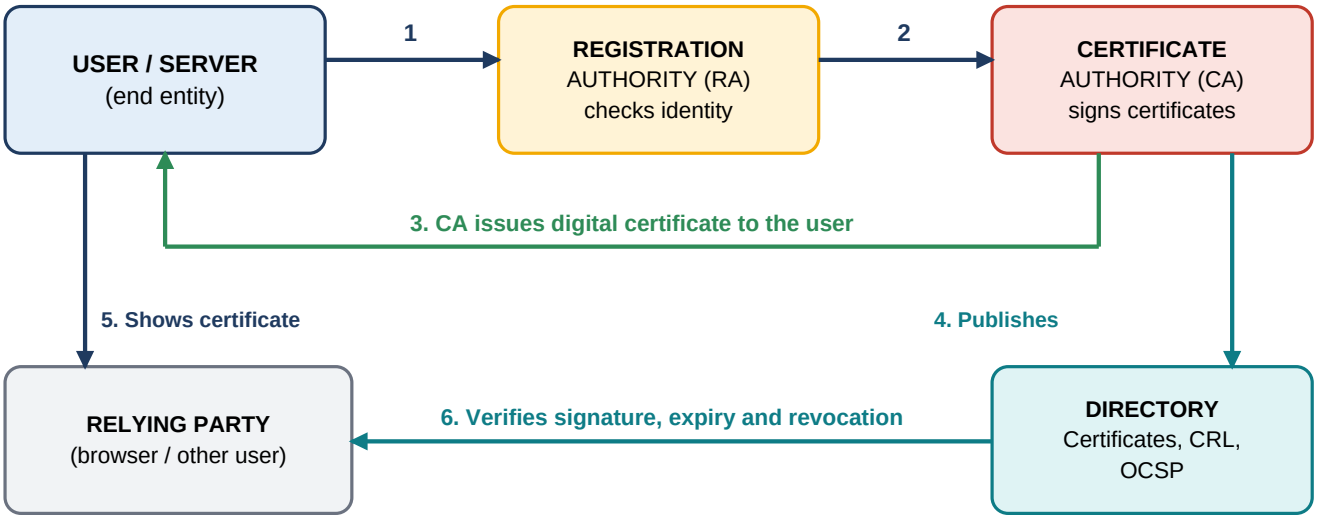


Figure 6: How PKI works

Certificate life cycle

- **1. Key generation:** user public/private key pair banata hai.
- **2. Request (CSR):** user public key aur identity details RA/CA ko bhejta hai.
- **3. Verification:** RA identity check karti hai.
- **4. Issue:** CA certificate sign karke issue karti hai.

- **5. Use:** certificate HTTPS, email, code signing, VPN me use hota hai.
- **6. Renewal ya revocation:** expiry se pehle renew hota hai, ya private key chori hone par revoke hota hai.

Digital Certificate (X.509)

- Isme owner ka naam, owner ki **public key**, validity dates, issuer (CA) ka naam, serial number aur **CA ka digital signature** hota hai.
- Browser certificate par tabhi bharosa karta hai jab wo trusted CA se signed ho, expire na hua ho aur domain name match kare.
- **Trust chain:** Root CA Intermediate CA ko sign karti hai, jo website certificate ko sign karti hai.

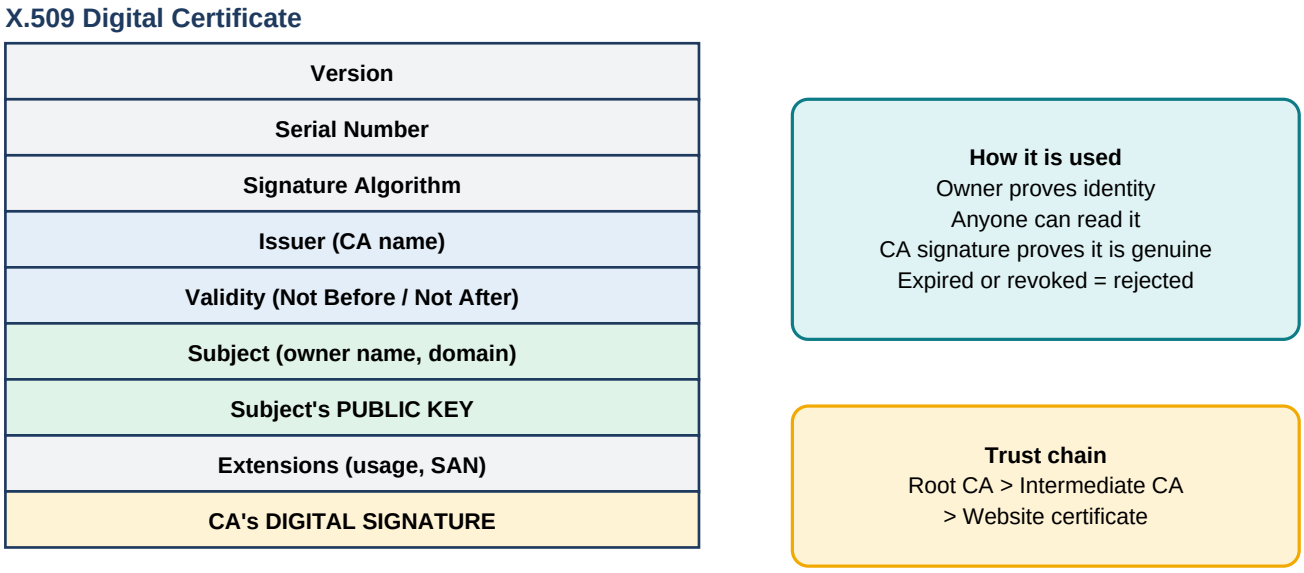


Figure 7: Structure of an X.509 digital certificate

Topic 4: Security Considerations while Developing Software

Real-life example

Agar builder ghar banate time lock aur majboot deewar bhool jaaye to baad me security lagana mehnga aur kamzor hota hai. Software bhi aisa hi hai: security ke baare me **shuru se** sochna chahiye, product ready hone ke baad nahi.

Definition

Secure software development ka matlab hai software ko aise design, code aur test karna ki vulnerabilities kam hon aur wo attacks se bacha rahe.

Common software vulnerabilities

- **Buffer overflow:** program buffer ki capacity se zyada data likh deta hai aur aas paas ki memory overwrite ho jaati hai.
- **SQL injection:** attacker input field me SQL commands daal kar database padhta ya badalta hai.
- **Cross-Site Scripting (XSS):** attacker malicious script inject karta hai jo doosre users ke browser me chalti hai.
- **Weak authentication / hard-coded passwords** code me.
- **Poor error handling:** detailed error messages system ki information leak kar dete hain.
- **Insecure data storage:** passwords ya data bina encryption/hashing ke save karna.
- **Purani libraries** jinme known bugs hain.

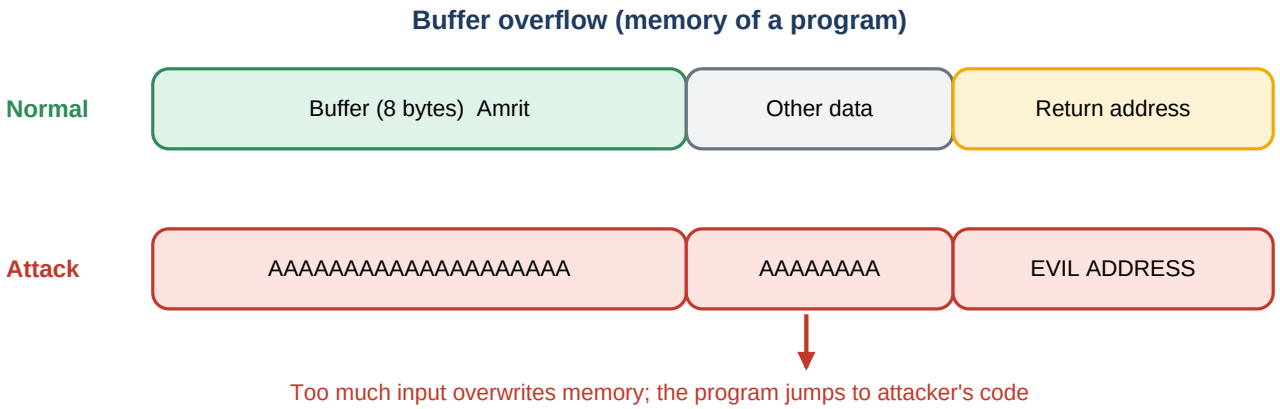


Figure 8: Buffer overflow attack

SQL injection example

Code me query: `SELECT * FROM users WHERE name='[input]' AND pass='[input]'`
Attacker input me `' OR '1'='1` likhe to condition hamesha true ho jaati hai aur login bypass ho jaata hai.
Fix: parameterized queries (prepared statements) aur input validation use karo.

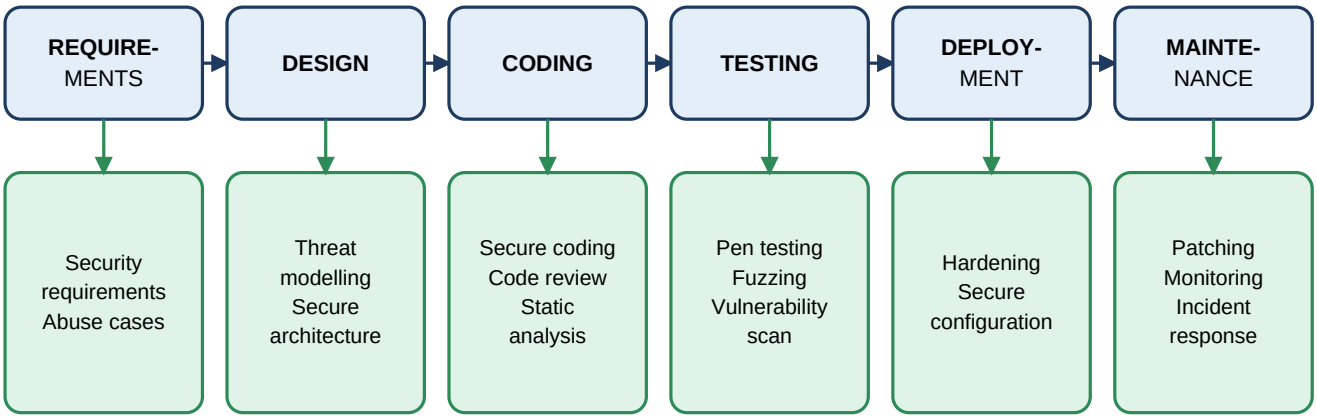
Secure coding practices (considerations)

- **Input validation:** user input par kabhi bharosa mat karo. Type, length aur format check karo.
- **Least privilege:** program kam se kam rights ke saath chale.
- **Secure authentication aur session management:** strong passwords, salt ke saath hashing, MFA, session timeout.
- **Sensitive data encrypt karo** storage me aur transit me (HTTPS/TLS).
- **Safe error handling aur logging:** users ko generic errors dikhao, details private log me rakho.
- **Secure defaults, defence in depth, fail-safe:** kai layers ki security rakho; failure par access deny karo.

- **Code review, testing aur patching:** static analysis, penetration testing, fuzzing, regular updates.
- **Trusted libraries use karo** aur **OWASP Top 10** jaise standards follow karo.

Secure SDLC

Software Development Life Cycle ke har phase me security jodi jaati hai.



Security activity in every phase (Secure SDLC)

Figure 9: Secure Software Development Life Cycle

PART B: Important Questions aur Model Answers (Hinglish)

Priority: **Very Likely** = BTEUP me sabse zyada aata hai. **Likely** = achha chance. **Possible** = aa sakta hai. Har answer exam format me hai: **Definition, Points, Diagram/Table, Conclusion**.

Q1. Cryptography kya hai? Uske basic terms aur types explain karo. — VERY LIKELY

Definition / Parichay: Cryptography information ko unreadable form me badal kar (encryption) protect karne ka science hai, taaki sirf authorized log use wapas readable form me la saken (decryption).

Points

- **Basic terms:** plaintext (original message), ciphertext (encrypted message), encryption, decryption, key (secret value), algorithm/cipher (method), cryptanalysis (cipher todna).
- **Goals:** confidentiality, integrity, authentication aur non-repudiation.
- **Types:** (1) Symmetric key (ek key), (2) Asymmetric key (public + private key), (3) Hash functions (key nahi).
- **Classical ciphers:** substitution (Caesar) aur transposition.

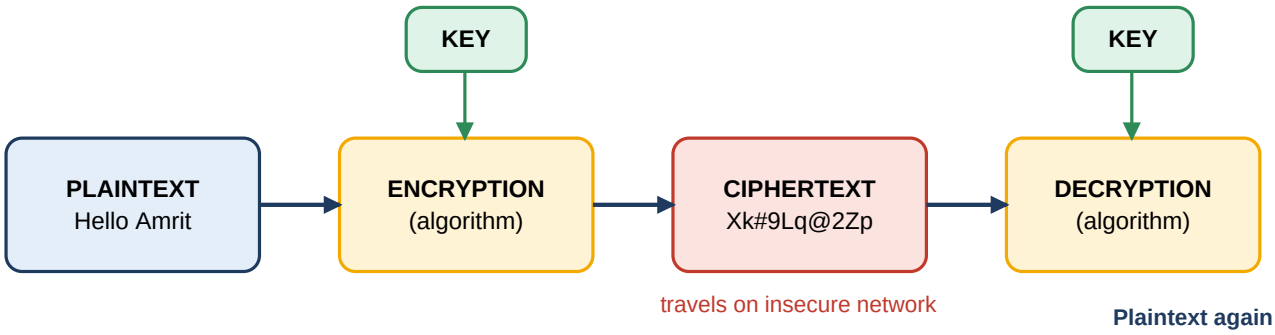


Figure: Encryption and decryption

Conclusion: Cryptography secure communication, e-commerce aur data protection ki buniyaad hai.

Q2. Symmetric Key Cryptography examples ke saath explain karo. VERY LIKELY

Definition / Parichay: Symmetric key cryptography me encryption aur decryption dono ke liye wahi secret key use hoti hai.

Points

- **Working:** sender shared key se encrypt karta hai; receiver wahi key se decrypt karta hai.
- **Advantages:** bahut fast, simple, bade data ke liye suitable.
- **Disadvantages:** key distribution problem; zyada users ke liye bahut keys chahiye (n(n-1)/2); non-repudiation nahi.
- **Examples:** DES (56-bit key, 64-bit block, 16 rounds), 3DES, AES (128/192/256-bit key), Blowfish, RC4.

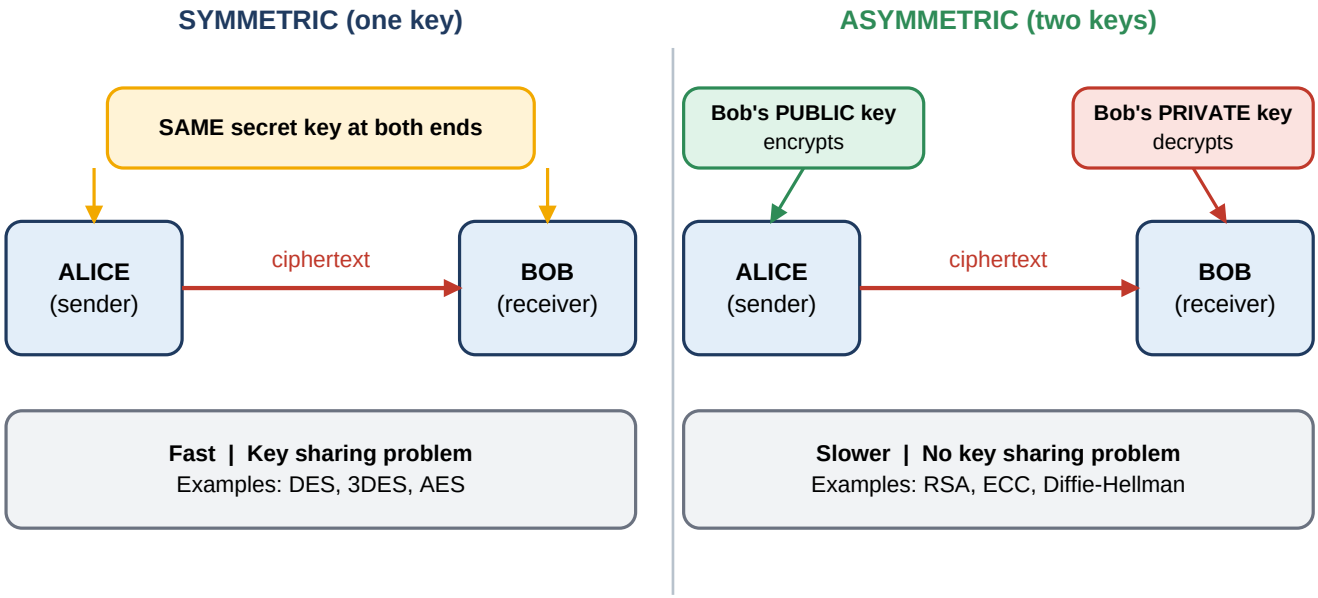


Figure: Symmetric and asymmetric cryptography

Point	DES	AES
Key size	56 bits	128 / 192 / 256 bits
Block size	64 bits	128 bits
Rounds	16	10 / 12 / 14
Security	Weak (purana)	Strong (current standard)

Conclusion: Symmetric cryptography fast hai aur bulk data ke liye best hai, par key safely share karne ka tarika chahiye.

Q3. Asymmetric Key Cryptography (RSA) explain karo. VERY LIKELY

Definition / Parichay: Asymmetric key (public key) cryptography me ek key pair hota hai: public key jo sabko pata hoti hai aur private key jo secret rehti hai. Ek key se encrypt hua data sirf doosri key se decrypt hota hai.

Points

- **Confidentiality:** sender receiver ki public key se encrypt karta hai; sirf receiver ki private key decrypt kar sakti hai.
- **Digital signature:** sender apni private key se sign karta hai; koi bhi uski public key se verify kar sakta hai.
- **RSA** (Rivest, Shamir, Adleman) do bade primes ke product ko factor karne ki mushkil par based hai. Key size 2048 bits ya zyada.
- **Other algorithms:** ECC, ElGamal, Diffie-Hellman (key exchange).
- **Advantages:** key sharing problem nahi, signatures support karta hai. **Disadvantage:** slow.

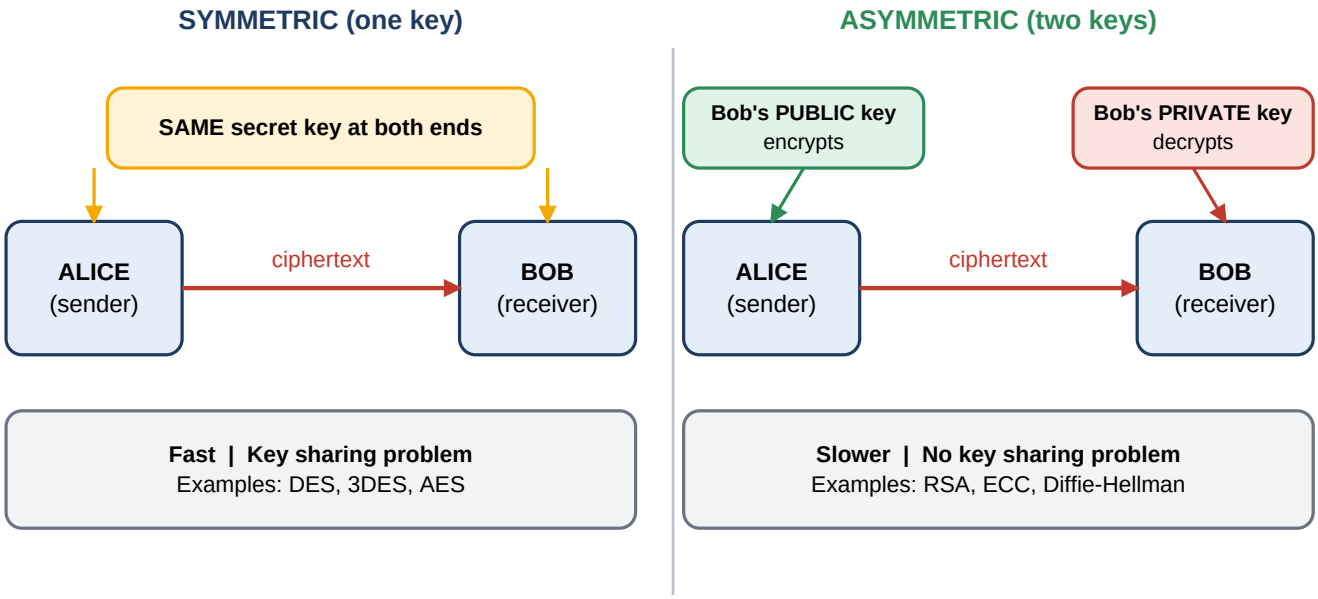


Figure: Symmetric and asymmetric cryptography

Conclusion: Asymmetric cryptography key distribution solve karta hai aur digital signatures possible banata hai; practice me ise symmetric ke saath use karte hain.

Q4. Symmetric aur Asymmetric key cryptography me difference likho. VERY LIKELY

Definition / Parichay: Symmetric cryptography ek shared secret key use karti hai, jabki asymmetric cryptography public-private key pair use karti hai.

Points

- Dono confidentiality dene ke liye use hote hain, par keys, speed aur use me alag hain.

Point	Symmetric	Asymmetric
Keys ki sankhya	Ek (same key)	Do (public + private)
Speed	Fast	Slow
Key sharing	Problem (secret key share karni padti hai)	Problem nahi (public key open hoti hai)
Best for	Bade data ke liye	Chhota data, keys, signatures
n users ke liye keys	n(n-1)/2	2n
Examples	DES, 3DES, AES	RSA, ECC, Diffie-Hellman

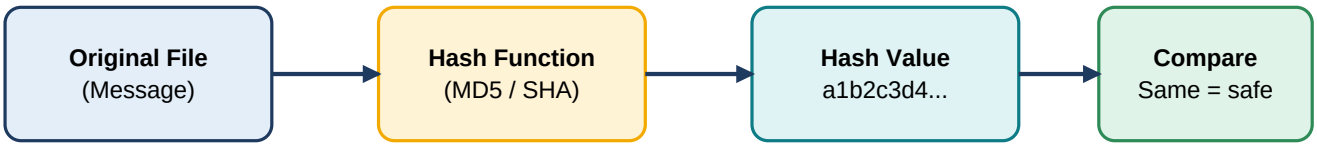
Conclusion: Practice me dono saath use hote hain (hybrid): key exchange ke liye asymmetric aur data ke liye symmetric.

Q5. Hash function kya hai? Uski properties aur uses explain karo. LIKELY

Definition / Parichay: Hash function kisi bhi size ka input leta hai aur fixed-size output deta hai jise hash value ya message digest kehte hain. Ye one-way hai aur isme key nahi hoti.

Points

- **Fixed output:** MD5 128 bits, SHA-1 160 bits, SHA-256 256 bits deta hai.
- **One-way (pre-image resistance):** hash se original data nahi nikala ja sakta.
- **Collision resistance:** same hash wale do inputs dhoondhna bahut mushkil hai.
- **Avalanche effect:** input me chhota badlaav hash ko poora badal deta hai.
- **Deterministic:** same input ka hash hamesha same hota hai.
- **Uses:** file integrity check, password storage, digital signatures, blockchain.



If even 1 character changes, the hash value changes completely (Integrity check)

Figure: Hash function and integrity check

Conclusion: Hash functions integrity deti hain aur digital signatures ka building block hain.

Q6. Digital Signature kya hai? Ye kaise kaam karta hai explain karo. LIKELY

Definition / Parichay: Digital signature ek value hai jo message ke hash ko sender ki private key se encrypt karke banti hai. Ye authentication, integrity aur non-repudiation deta hai.

Points

- **Signing:** sender message ka hash (digest) nikalta hai aur use apni private key se encrypt karta hai. Yahi signature hai.
- Sender message aur signature dono bhejta hai.
- **Verification:** receiver signature ko sender ki public key se decrypt karke Digest 1 pata karta hai, aur mile hue message ka hash nikal kar Digest 2 banata hai.
- Digest 1 = Digest 2 ho to message asli aur unchanged hai; nahi to reject hota hai.

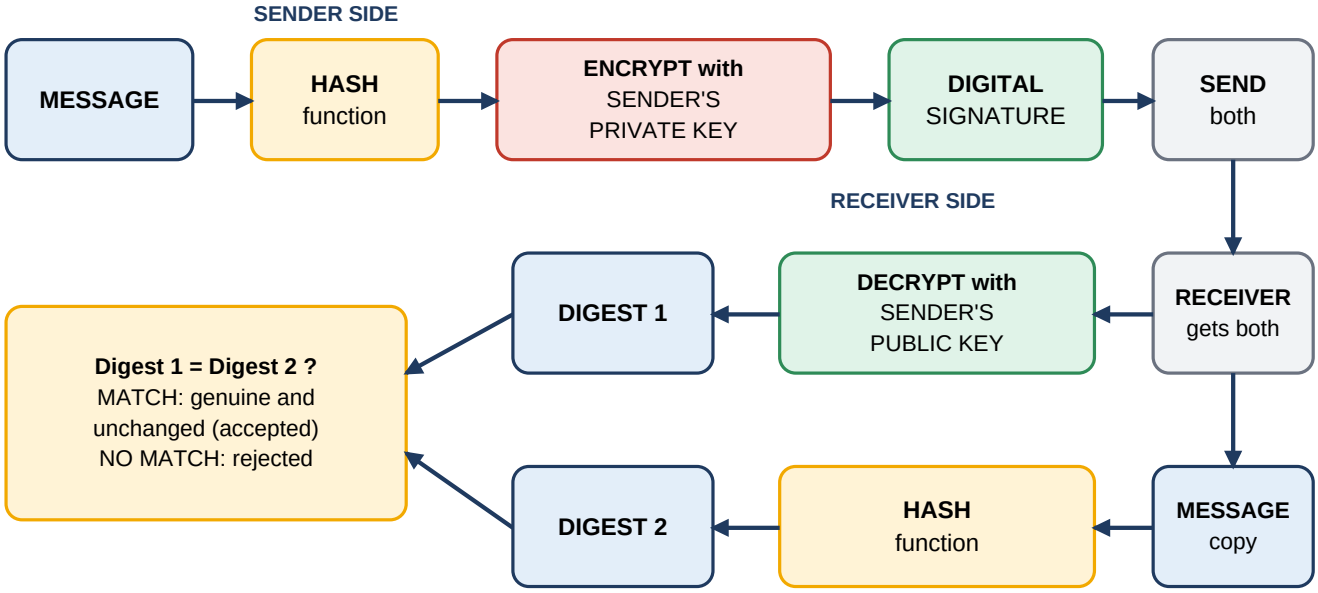


Figure: Digital signature process

Conclusion: Digital signatures e-governance, online banking, software distribution aur legal documents me use hote hain.

Q7. PKI kya hai? Uske components aur working explain karo. VERY LIKELY

Definition / Parichay: PKI (Public Key Infrastructure) logon, policies aur technology ka framework hai jo digital certificates ko create, manage, distribute aur revoke karta hai, taaki public keys par bharosa kiya ja sake.

Points

- **Certificate Authority (CA):** trusted body jo certificates issue karti hai aur digitally sign karti hai.
- **Registration Authority (RA):** CA ke liye applicant ki identity verify karti hai.
- **Digital certificate (X.509):** public key ko uske owner se bind karta hai.
- **Directory / repository:** certificates store karti hai; **CRL / OCSP:** revoked certificates ki list ya service.
- **Working:** user certificate maangta hai, RA identity verify karti hai, CA issue karti hai, user use dikhata hai, aur doosre CA ka signature, validity period aur revocation status check karte hain.

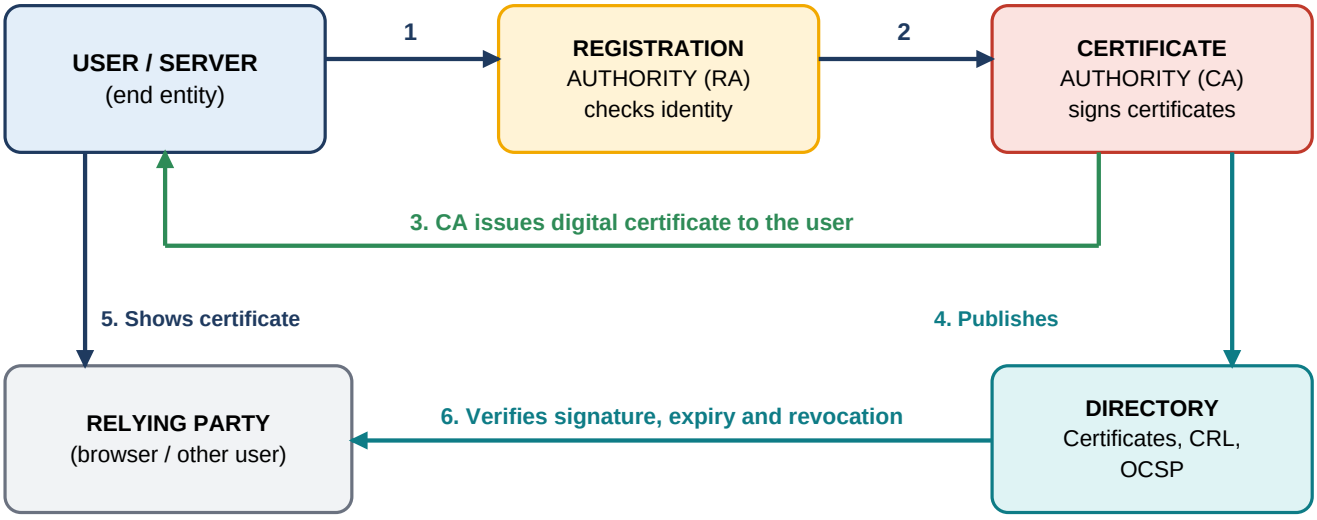


Figure: Working of PKI

Conclusion: PKI internet par trust deta hai aur HTTPS, secure email, VPN aur digital signatures ko support karta hai.

Q8. Digital Certificate kya hai? Uske contents explain karo. LIKELY

Definition / Parichay: Digital certificate ek electronic document hai, jo Certificate Authority issue aur sign karti hai, aur public key ki ownership prove karta hai. Standard format X.509 hai.

Points

- **Contents:** version, serial number, signature algorithm, issuer (CA) ka naam, validity period, subject (owner) ka naam, subject ki public key, extensions aur CA ka digital signature.
- **Verification:** browser check karta hai ki CA trusted hai, signature valid hai, certificate expire ya revoke nahi hua, aur domain match karta hai.
- **Trust chain:** Root CA, phir Intermediate CA, phir end certificate.
- **Uses:** HTTPS websites, email security (S/MIME), code signing, VPN, smart cards.

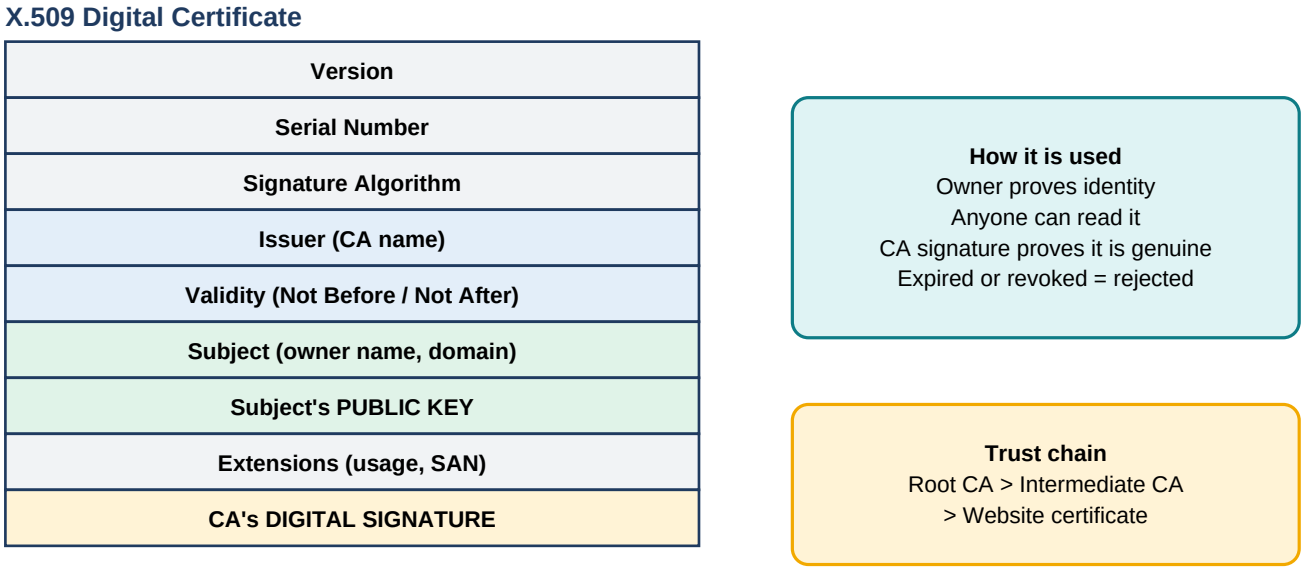


Figure: X.509 certificate structure

Conclusion: Digital certificates se users owner se mile bina public key par bharosa kar sakte hain.

Q9. Caesar cipher explain karo. Substitution aur transposition ciphers kya hain? — POSSIBLE

Definition / Parichay: Classical ciphers purane encryption methods hain. Inke do basic types hain: substitution aur transposition.

Points

- **Substitution cipher:** har letter ko doosre letter ya symbol se badla jaata hai.
- **Caesar cipher:** har letter ko fixed number (key) se shift kiya jaata hai. Shift 3 me: A se D, B se E, aur aage bhi aise. Formula: C = (P + k) mod 26 aur P = (C - k) mod 26.
- **Example:** HELLO ko shift 3 se encrypt karo to KHOOR banta hai.
- **Transposition cipher:** letters nahi badalte, sirf unki positions badalti hain (jaise text ko rows me likh kar columns me padhna).
- **Weakness:** Caesar cipher me sirf 25 keys hoti hain, isliye brute force aur frequency analysis se aasani se tut jaata hai.

Caesar cipher (shift = 3): each letter moves 3 places forward

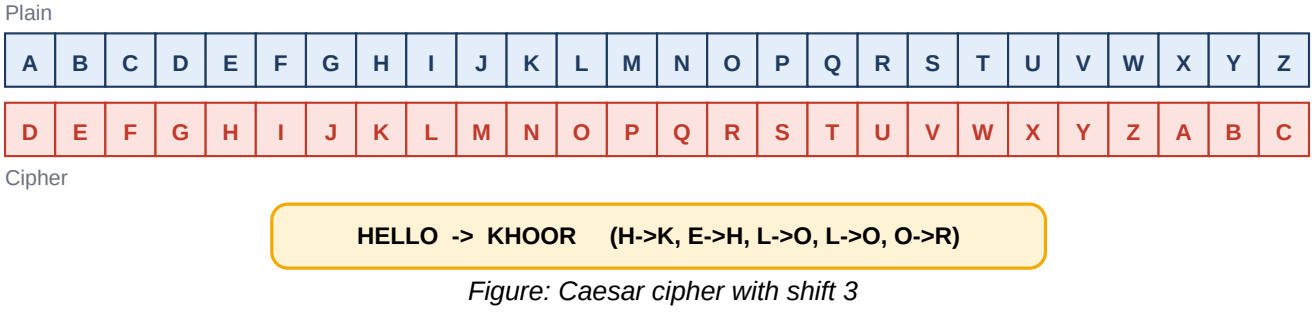


Figure: Caesar cipher with shift 3

Conclusion: Classical ciphers aaj secure nahi hain, par ye modern cryptography ke basic ideas samjhate hain.

Q10. Software develop karte waqt security considerations explain karo. — VERY LIKELY

Definition / Parichay: Secure software development ka matlab hai software aise banana ki vulnerabilities kam hon aur wo attacks jhel sake. Security ko development ke shuru se hi sochna chahiye.

Points

- **Input validation:** sabhi user input ka type, length aur format check karo; us par bharosa mat karo.
- **Authentication aur session management:** strong passwords, salted hashing, MFA, session timeout.
- **Least privilege:** code ko kam se kam rights ke saath chalao.
- **Data protection:** sensitive data storage aur transit me encrypt karo; passwords ya keys code me hard-code mat karo.
- **Error handling aur logging:** users ko internal details mat dikhao.
- **Defence in depth aur secure defaults:** kai layers; default me deny.
- **Testing aur maintenance:** code review, static analysis, penetration testing, regular patches, updated libraries, OWASP Top 10 follow karo.

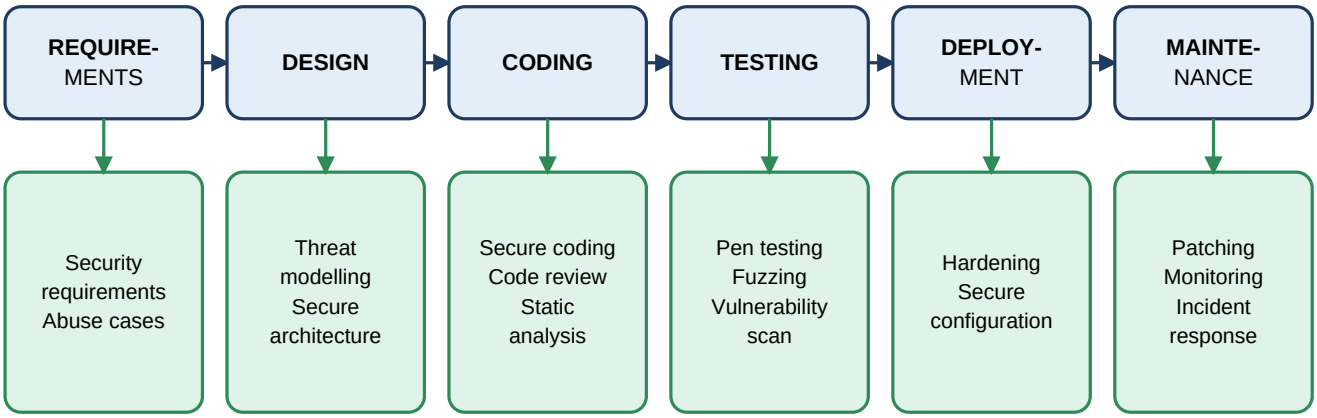


Figure: Security in every phase of development

Conclusion: Security ko shuru se build karna release ke baad problems fix karne se sasta aur safe hota hai.

Q11. SQL Injection, XSS aur Buffer Overflow vulnerabilities aur unki prevention explain karo.

LIKELY

Definition / Parichay: Ye teen sabse common software vulnerabilities hain, jo input ko sahi se handle na karne se hoti hain.

Points

- **SQL injection:** attacker form me SQL code (jaise `' OR '1'='1`) daal kar login bypass karta hai ya database padhta hai. **Prevention:** parameterized queries, input validation, least-privilege database account.
- **Cross-Site Scripting (XSS):** attacker web page me script inject karta hai jo doosre users ke browser me chalti hai aur cookies chura leti hai. **Prevention:** output encoding, input validation, Content Security Policy, HttpOnly cookies.
- **Buffer overflow:** buffer size se zyada data aas paas ki memory (jaise return address) overwrite kar deta hai, jisse attacker apna code chala sakta hai. **Prevention:** bounds checking, safe functions (strcpy ki jagah strncpy), stack canaries, ASLR, DEP.

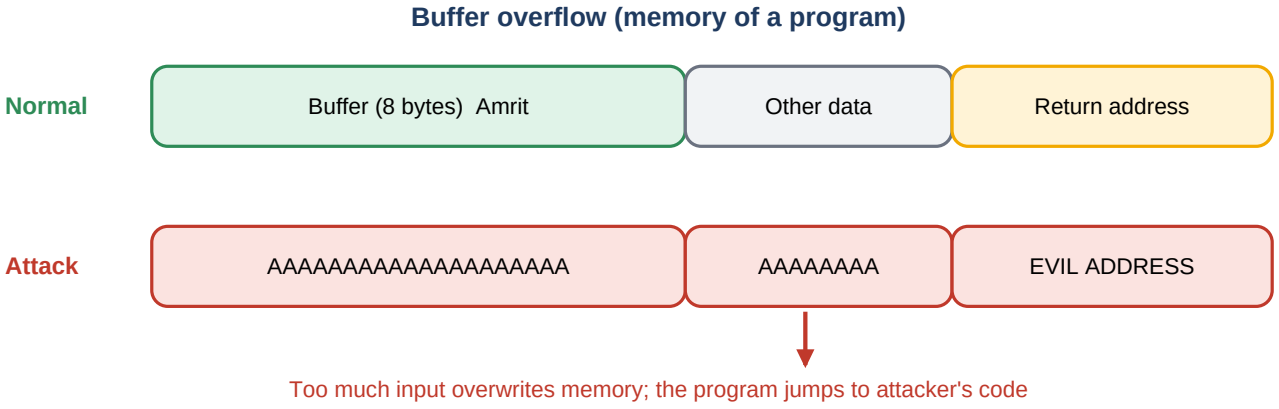


Figure: Buffer overflow

Attack	Target	Main fix
SQL injection	Database	Parameterized queries
XSS	Users ke browsers	Output encoding, CSP
Buffer overflow	Program memory	Bounds checking, safe functions

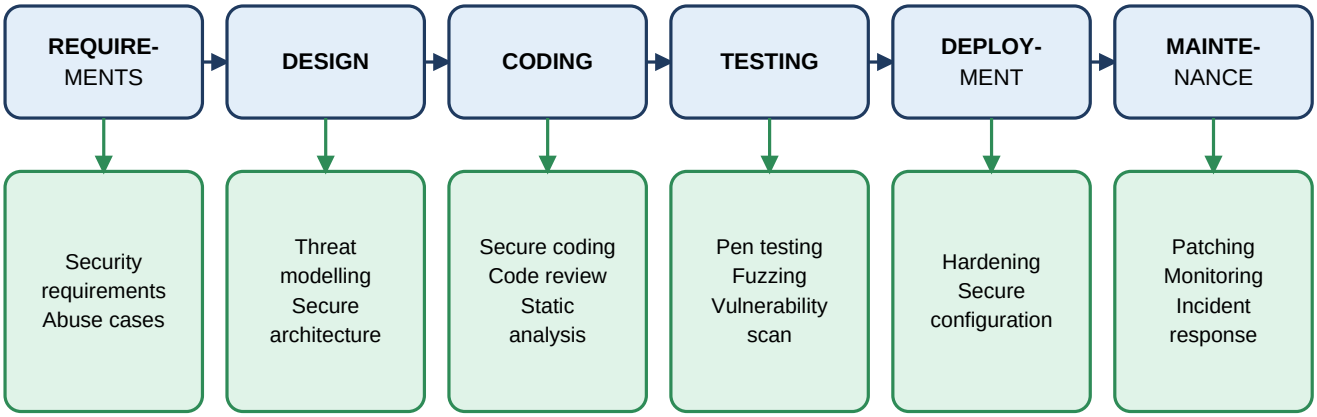
Conclusion: Input validate karne aur safe coding functions use karne se in me se zyada tar attacks ruk jaate hain.

Q12. Secure SDLC (Software Development Life Cycle) explain karo. POSSIBLE

Definition / Parichay: Secure SDLC security activities ko software development life cycle ke har phase me jodta hai, sirf end me security test karne ke bajay.

Points

- **Requirements:** security requirements aur abuse cases define karo.
- **Design:** threat modelling aur secure architecture.
- **Coding:** secure coding standards, code review, static analysis.
- **Testing:** penetration testing, fuzzing, vulnerability scanning.
- **Deployment:** hardening aur secure configuration.
- **Maintenance:** patching, monitoring aur incident response.



Security activity in every phase (Secure SDLC)

Figure: Secure SDLC

Conclusion: Secure SDLC vulnerabilities aur unhe fix karne ki cost kam karta hai.

Quick Revision Sheet (exam se pehle raat ko padho)

Term	Ye yaad rakho
Cryptography	Algorithm + key se plaintext se ciphertext
Goals	Confidentiality, Integrity, Authentication, Non-repudiation
Caesar cipher	C = (P + k) mod 26. HELLO (k=3) = KHOOR
Substitution / Transposition	Letters badlo / Positions badlo
Symmetric	Ek key, fast. DES (56-bit), AES (128/192/256)
Asymmetric	Public + private key, slow. RSA, ECC, Diffie-Hellman
Encrypt for confidentiality	Receiver ki PUBLIC key encrypt, PRIVATE key decrypt
Digital signature	Hash + sender ki PRIVATE key. PUBLIC key se verify
Hash	One-way, fixed size, key nahi. MD5 128, SHA-1 160, SHA-256
PKI	CA, RA, certificate, directory, CRL/OCSP
X.509 certificate	Owner, public key, issuer, validity, CA signature
Trust chain	Root CA > Intermediate CA > End certificate
SQL injection	Fix: parameterized queries
XSS	Script doosre ke browser me chalti hai. Fix: output encoding, CSP
Buffer overflow	Fix: bounds check, strncpy, ASLR, canaries
Secure SDLC	Sabhi 6 phases me security: Req, Design, Code, Test, Deploy, Maintain

Yaad rakhne ke tricks

Kaunsi key? Secrecy ke liye lock = receiver ki PUBLIC key. Proof ke liye sign = meri PRIVATE key.
PKI parts: C-R-C-D = CA, RA, Certificate, Directory.
Hash: O-F-C-A = One-way, Fixed size, Collision resistant, Avalanche.
Symmetric = Same key. Asymmetric = Alag key.

Common Mistakes jo Students Karte Hain

- Keys mix karna: **encryption receiver ki public key** se hota hai, par **signature sender ki private key** se banta hai.
- Hash function me key hoti hai ya ulta ho sakta hai, aisa likhna. Ye **keyless aur one-way** hai.
- **Encryption** (key se reversible) aur **hashing** (reversible nahi) ko mix karna.
- **CA** (certificate issue karti hai) aur **RA** (identity verify karti hai) ke roles mix karna.
- SQL injection, XSS aur buffer overflow me sirf attack likhna aur **prevention** bhool jana.
- Diagrams na banana (encryption flow, digital signature, PKI).

Self-Test (bina dekhe likho, har question 5 marks)

- Symmetric aur asymmetric cryptography me difference likho, examples ke saath.
- Digital signature ki working diagram ke saath explain karo.
- PKI kya hai? Uske components explain karo.
- HELLO ko Caesar cipher (shift 3) se encrypt karo. Formula likho.
- SQL injection kya hai? Ise kaise roka ja sakta hai?

Self-Test Answers (likhne ke baad check karo)

1. Symmetric: ek shared key, fast, key sharing problem, jaise AES, DES. Asymmetric: public + private key pair, slow, key sharing problem nahi, signatures support, jaise RSA, ECC. Q4 ki table banao.

2. Sender message ka hash banakar use apni private key se encrypt karta hai (signature) aur dono bhejta hai. Receiver signature ko sender ki public key se decrypt karta hai (Digest 1), message ka hash banata hai (Digest 2) aur compare karta hai. Barabar ho to asli aur unchanged. Figure 5 banao.

3. PKI digital certificates ko create, manage, distribute aur revoke karne ka framework hai. Components: CA, RA, digital certificate, directory/repository, CRL/OCSP, key pairs.

4. Formula: C = (P + k) mod 26. H+3 = K, E+3 = H, L+3 = O, L+3 = O, O+3 = R. Isliye HELLO ka answer **KHOOR** hai.

5. SQL injection me attacker input field me SQL code (jaise ' OR '1'='1) daal kar login bypass karta hai ya database access karta hai. Prevention: parameterized queries, input validation aur least-privilege database account.

> **Unit 3 complete!**
> Agar 5 me se 4 ya zyada sahi hue to **Unit 4** par jao. Nahi to Part A me jo topics miss hue unhe dobara padho.